

CS254 – Network Security

Introduction

Jan 6, 2025

Outline



- Welcome!
- Goals of this course
 - ▣ Get to know interesting network security topics
 - ▣ Introduction to research
- Exercises
- Grading

Self intro



- Zhiyun Qian
- CSE Prof.
- Web: <https://www.cs.ucr.edu/~zhiyunq>
- Course webpage:
<https://www.cs.ucr.edu/~zhiyunq/teaching/cs254/>
- iLearn for announcements and materials
- Office hours (tentative): Wed 11 to noon

Past research - Vulnerable Firewall

4

 **Check Point**
SOFTWARE TECHNOLOGIES LTD.

Global Sites  | My Account 

Home | Products & Services | Buy | **Support** | About Us

 [Support Center](#) > [Search Results](#) > SecureKnowledge Details

Support Center



 Print  Email

Check Point response to "Off-Path TCP Sequence Number Inference Attack"

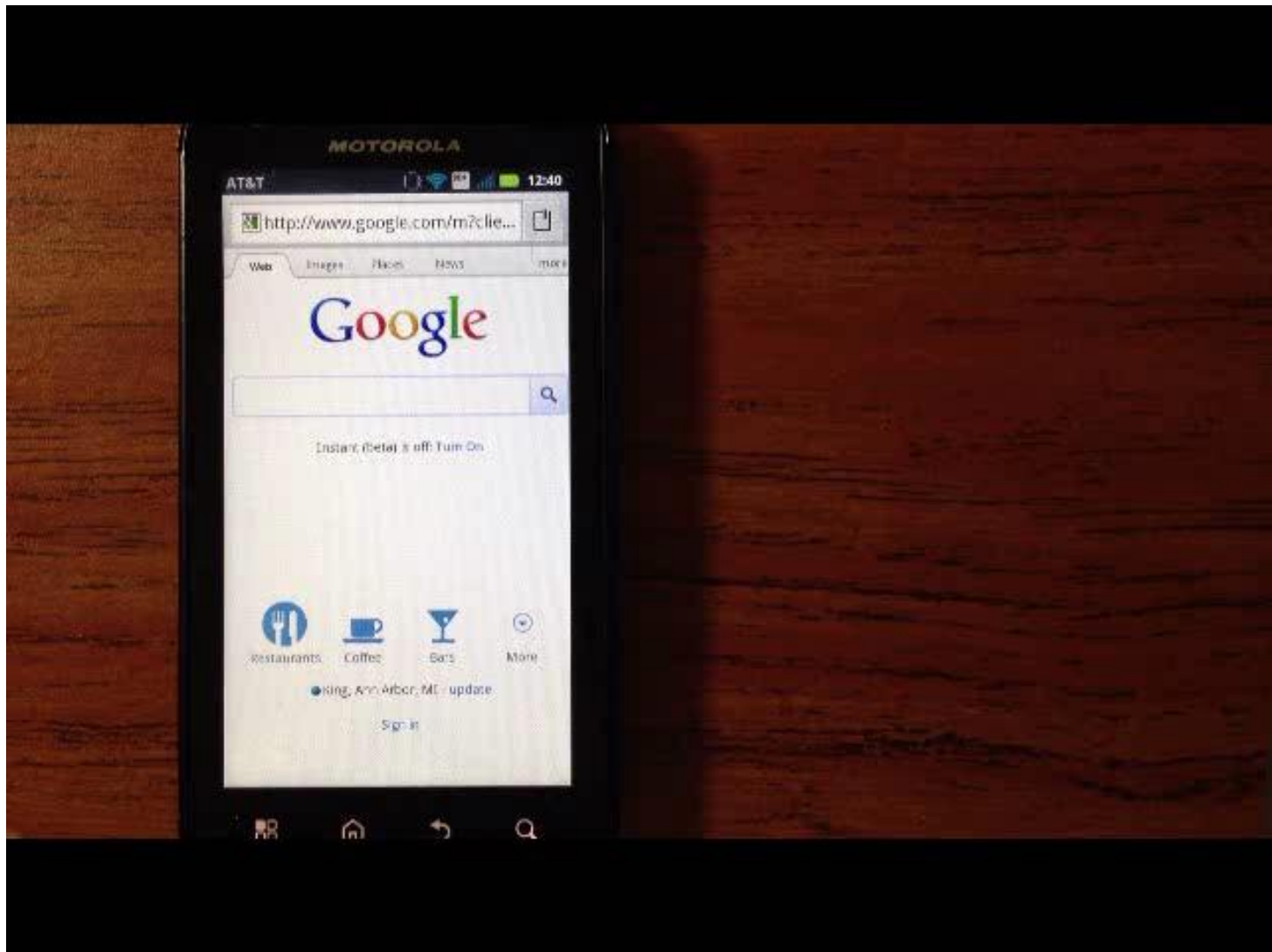
Solution ID: sk74640
Severity: **Low**
Product: Security Gateway
Version: All
Date Created: 24-May-2012
Last Modified: 14-Mar-2013

Rate this document
☆☆☆☆☆ [1=Worst,5=Best]

SYMPTOMS

- Researchers at the University of Michigan have published a paper ["Off-Path TCP Sequence Number Inference Attack How Firewall Middleboxes Reduce Security"](#).
- This attack identifies the current sequence range of a TCP connection, by exploiting the fact that firewalls drop out-of-window TCP packets. After the sequence range is identified, an off-path attacker may inject data or hijack the TCP connection.
- Client applications that use cleartext connections (e.g., HTTP and not HTTPS) are potential targets for these attacks.

Past research – TCP side channels

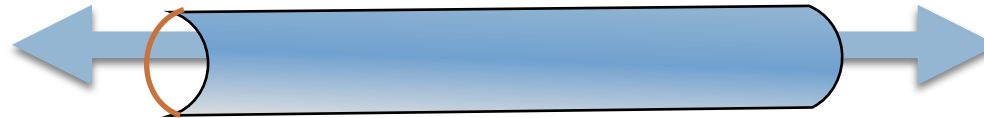


Past research – TCP remote hijack

CVE-2016-5969



Client



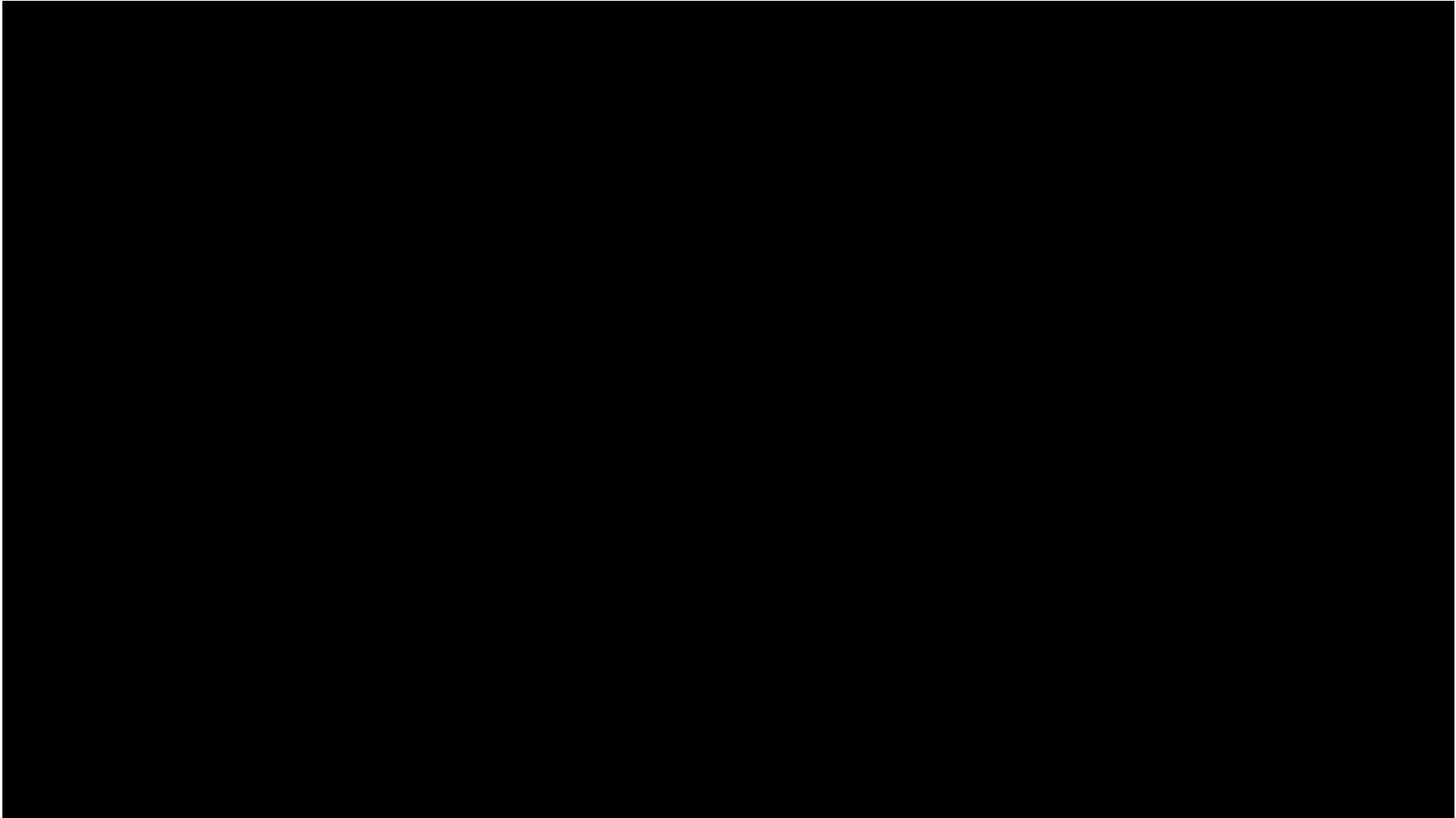
Server



Attacker

Past research – TCP remote hijack

<https://youtu.be/S4Ns5wla9DY>



Past research – DNS cache poisoning

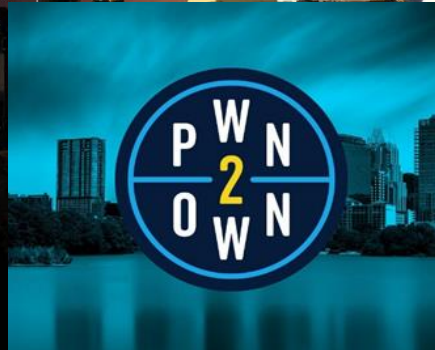


Hacking competitions



1200 - The NullRiver team of Xin'an Zhou, Xiaochen Zou, Zhiyun Qian targeting the LAN interface of the NETGEAR R6700v3 in the router category

SUCCESS - The team used a pair of bugs to execute code via the LAN interface. They earn \$5,000 and 1 Master of Pwn point.



Goals of this course

- Broaden your knowledge about cyber
 - ▣ What can possibly go wrong in networked systems?
- Gain hands-on experience (not just theory)
 - ▣ Evaluating security of networked systems
 - ▣ Break and fix things
- Prepare for research
 - ▣ Topics in network security
 - ▣ Identify interesting areas

Getting an A

- This class requires knowledge of networking (and perhaps a bit of operating system)
- And also a mature understanding of software and systems

Who are you?

- Name? PhD or MS? Which year?
- What are your area of interest?
- How do you plan to tie your interest with security?

What do we study in security?

- How a system behaves under “adversarial actions”

Security research

vs.

System research

||

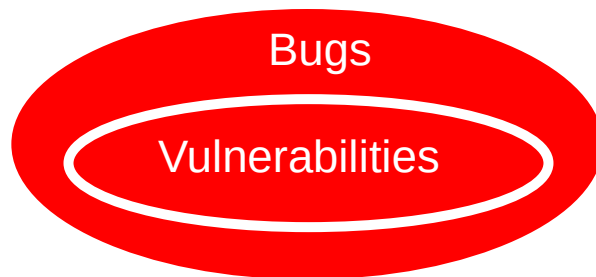
||

Corner cases

vs.

Common cases

||

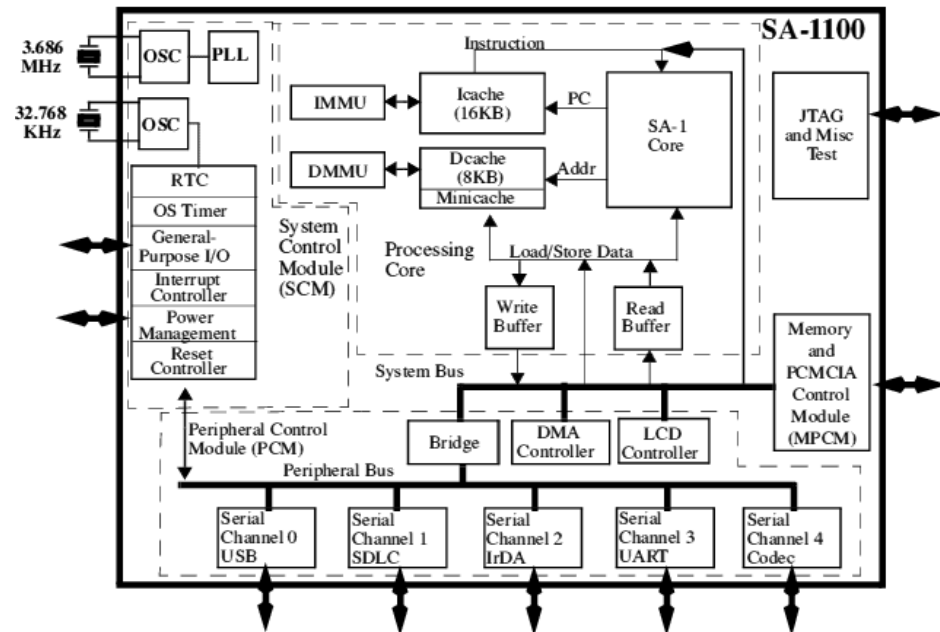


What is security research?



Play Games vs. Research Security

- Both deal with a set of man-made rules!
- Man-made rules have bugs (which can be exploited)!
 - ▣ Think about tax systems...



Who does security research?

- ❑ Academia
- ❑ Industry
- ❑ Military
- ❑ Government
- ❑ Hobbyists
- ❑ Bad guys...

On the news

- ❑ Microsoft Exchange Server Breach (2021): 250,000 servers worldwide.
- ❑ Log4j Vulnerability (2021): remote code execution
- ❑ Pumpkin Eclipse DDoS attack (2023): 600,000 SOHO routers bricked



Topics

- Network protocols
 - ▣ TCP/IP, DNS
 - ▣ Basic crypto: SSL/TLS, HTTPS
- Network threats
 - ▣ Reconnaissance
 - ▣ Botnet
 - ▣ Underground economy
 - ▣ Censorship
- Network defenses
 - ▣ Firewall
 - ▣ Network intrusion detection systems
 - ▣ Anonymous communication

Not a theory
class

Why study attacks?

□ Research

- ▣ Understand limitations of existing systems (e.g., false assumptions)
- ▣ Identify new classes of attacks
- ▣ Motivate research on new defenses

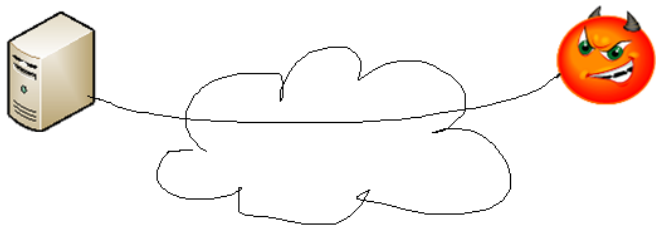
□ Also

- ▣ Fix problems before the attackers find them
- ▣ Pressure vendors so they improve their system
- ▣ Help designers determine the right threat models
- ▣ Help users more accurately evaluate risk

Common security terms

□ Threat model

- ▣ What capabilities / motivations the attacker has?



vs.



vs.



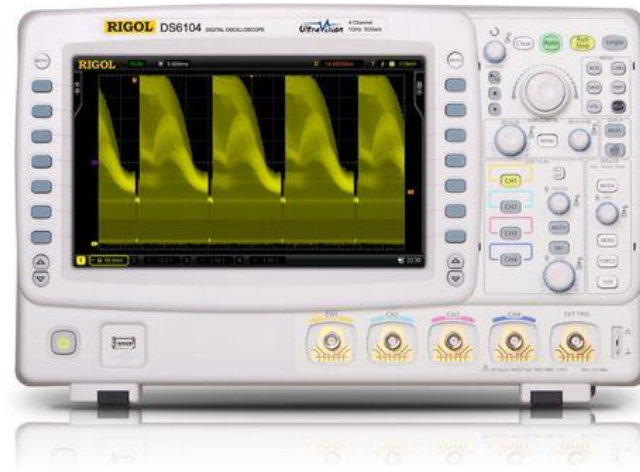
Weakness < Vulnerability < Exploit < Attack

Thinking like an attacker

- Analyze a system with different goals (threats)
 - ▣ Break into a door? Steal? Fake identity?
- Think outside the box
 - ▣ Side channel attacks (e.g., steal crypto keys)
- Is security of a system depends



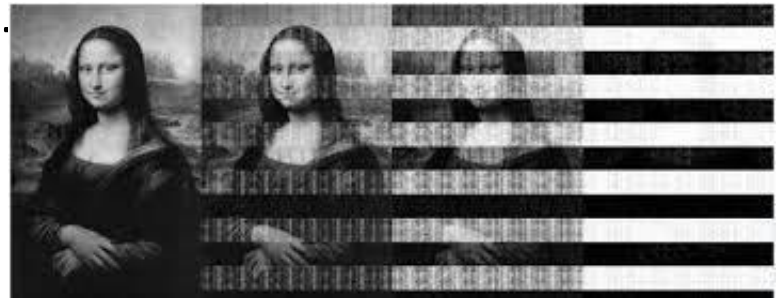
oken
syste
ck ca



Thinking like an attacker

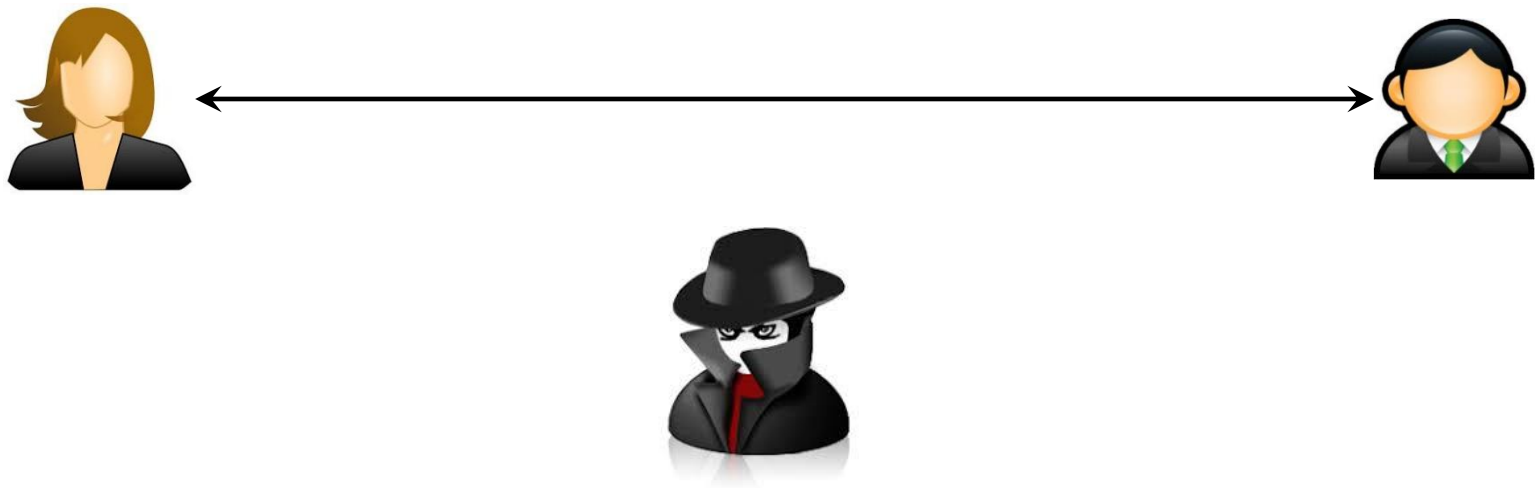
- Analyze a system with different goals (threats)
 - ▣ Break into a door? Steal? Fake identity?
- Think outside the box
 - ▣ Side channel attacks (e.g., steal crypto keys)
- Identify assumptions security of a system depends on – can they be broken?
 - ▣ Full-disk encryption: physical access to a system

- (...) attack s



Thinking like an attacker

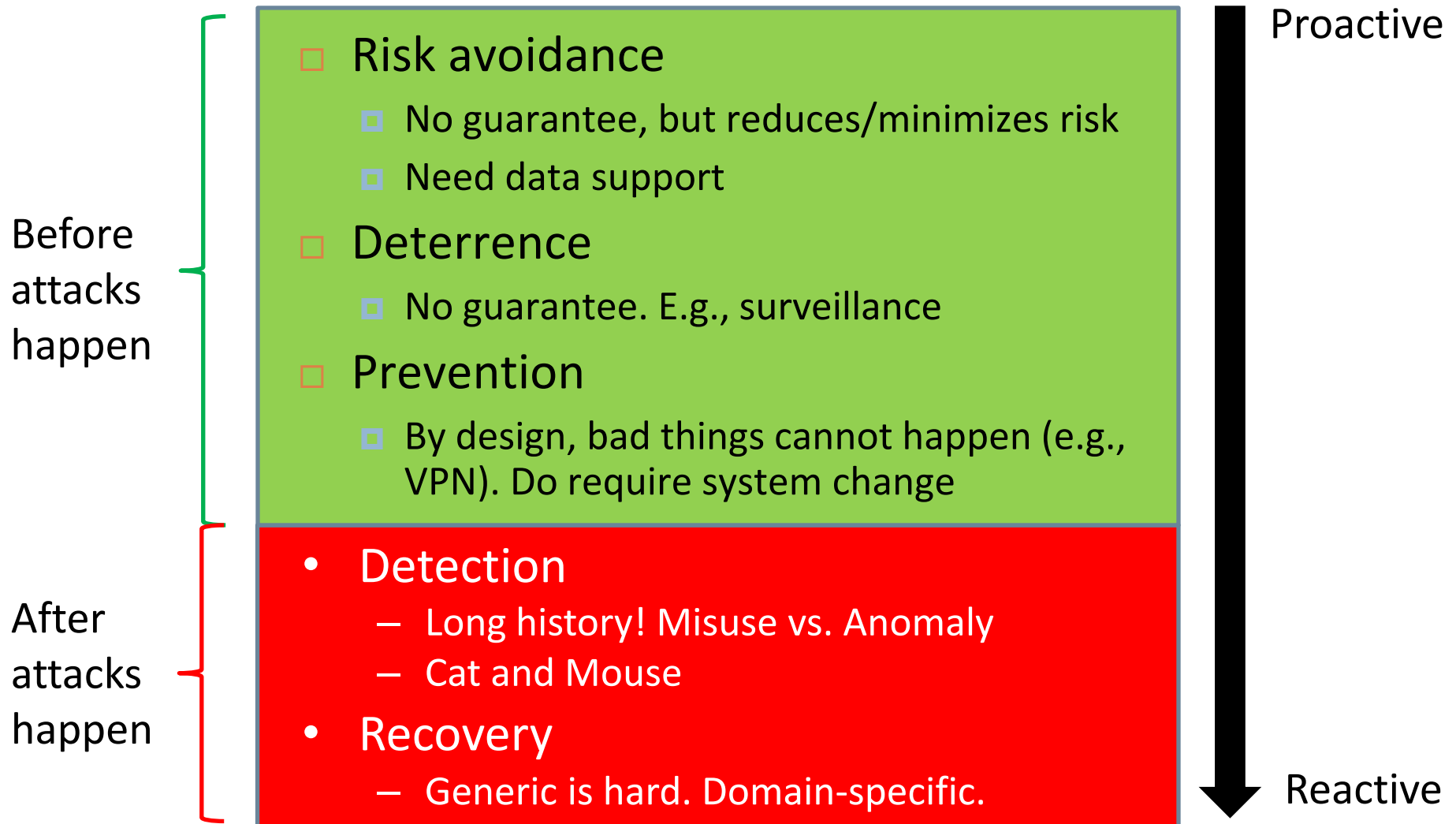
- Exercise: What can possibly go wrong when two parties are communicating?



Thinking like a defender

- Threat model – what attacks to defend?
 - ▣ Rigorously reason over all possibilities
- What properties to protect?
 - ▣ Confidentiality, Integrity, Availability, Non-repudiation, etc.
- Practicality
 - ▣ Cost vs. Benefit
 - ▣ Incentives: e.g., encryption, filtering of bad traffic

Security - Functional View



Grading

- Paper response and class participation: 25%
- Attack and tool presentation: 25%
- Project: 50%

- No exams!

Paper response & class participation – 25%

- 1 or 2 papers each session
 - ▣ Other readings are recommended but optional
- Come prepared to contribute!
 - ▣ Beginning discussions led by me
 - ▣ Volunteers get extra credits for leading the discussions
- Points given to
 - ▣ Constructive/creative comments
 - ▣ Speaking up during the class to contribute in critics and ideas
- Points lost for
 - ▣ Missing classes
 - ▣ Not participating in discussions

Paper response & class participation – 25%

□ Extracting key ideas and insights

- ▣ How do you think the authors come up with the idea?
- ▣ What is/are the observation(s) that led to the whole paper?
- ▣ What high-level principles did the paper follow?
 - E.g., security by randomization, security by injecting noise (chaff)

□ Generalization

- ▣ Does the solution cover the entire problem space? If not, what can be done to cover the more general space?
- ▣ Can the idea/insight be applied to other problems?

Paper response & class participation – 25%

- Most important skill: critical thinking
 - ▣ Is there an implicit assumption not discussed? Does it really hold in practice?
 - E.g., A defense is designed to stop attack X. But why is attack Y out-of-the-picture if X and Y have the same attack requirements?
 - ▣ Are the good results really coming from the key idea in the solution instead of other artifacts?
 - E.g., A solution includes components X, Y, Z. How do we know which one contributed the most? And maybe there is a dataset bias favoring their solution.
 - ▣ Limitations of the approach?
 - E.g., Why do you think the solution is not deployed in practice?
- Alternative solutions
 - ▣ Would another solution achieve the same or better results?
 - ▣ What are the tradeoff space and why is the proposed solution in the “sweet spot” compared to alternatives?

Paper response and discussion

31

- What should be included in the summary?
 - ▣ Problem, approach, main contribution
 - ▣ Key insight and novelty. Generalization.
 - ▣ Weakness / limitations. Alternative approaches?
 - ▣ Other discussion points: whose job is easier, attacker or defender? Any inspirations?
- Due before class (ilearn)

Attack or Tool presentation – 25%

- Pointers will be given to students
 - ▣ Individual, 8 mins of presentation
 - ▣ Scheduled in week 6
- Either
 - ▣ Choose one attack/exploit/vulnerability (avoid overlap)
 - ▣ Explain the attack/vulnerability (demo)
 - ▣ Extra points to implement or generalize the attack
- or
 - ▣ Pick a security tool (preferably new and popular)
 - ▣ Demo it and explain how it works roughly

Research project – 50%

- A list will be given or you can choose your own
 - ▣ 2 students form a group (individual is also fine)
 - ▣ Grading based on contribution percentage
- General goals
 - ▣ Analyze a system to identify weaknesses
 - ▣ Propose a new defense / **Re-implement** or adapt a known work
 - ▣ Aim for a publishable workshop paper (or something you can brag about)
- Sample projects
 - ▣ Improve a censorship evasion tool
 - ▣ (re-)Implement a small measurement tool
 - ▣ (re-)Implement an attack against SSL/TLS
 - ▣ design a network CTF question

Research project – 50%

□ Timeline

- ▣ Topic discussion during office hours (also in class)
- ▣ Week 2: Initial idea on project due
- ▣ Week 4: 8-min pre-proposal presentation due
- ▣ End of Week 4: 3-page proposal due
- ▣ Week 10: final presentation, Week 11: 10-page final report due

□ Three virtual meetings with me

- ▣ One for picking a project
- ▣ One before pre-proposal
- ▣ One before the final presentation